Table of Contents

What Software was implemented and why? ***2***

DB Beaver **2**

PostgreSQL **2**

Samba **2**

WPS office **3**

Security Policies and Security software. ***4***

Nessus **4**

Wazuh **4**

Security Controls **4**

Group Policy **5**

CIS Benchmarks v8 ..... **5**

Network Topology, DC Topology, and Redundancy. ***7***

Network Topology **7**

Why a Star Topology Was Chosen 7

Consideration of This Design 7

Domain Controller Topology **7**

Primary Functions of the Domain Controller 8

Why the Domain Controller Is Important 8

Redundancy **8**

Redundancy in Gulf Coast Dentistry 8

Benefits of Redundancy 9

Backups **9**

Backup Strategy at Gulf Coast Dentistry 9

Why Backups Are Necessary 9

Conclusion 9

Finances/Where we are headed ***10***

What Software was implemented and why?

DB Beaver

- What does DB Beaver do?
  - DB Beaver is a graphical interface that allows your staff to connect to, manage, and query your PostgreSQL database.
  - It allows authorized users to create and modify databases and manage users and permissions
  - Also allows you to export and import data
- Why do we use it?
  - Instead of requiring our staff to learn how to use the command line interface and SQL commands, they can manage the database through a GUI, or Graphical User Interface.
  - It allows them to edit data in a spreadsheet like manner.
  - It supports verification of data integrity.
  - It helps your staff to debug issues without having to ask the IT team every time an issue arises.

PostgreSQL

- What does PostgreSQL do?
  - Postgres is an open-source relational database management system.
  - It stores data in tables,
  - Runs queries using SQL, or structured query language.
  - Manages Users and permissions, transactions (for data consistency), and backups and recovery.
- Why do we use it?
  - It is free of charge.
  - It stores your patient records, appointments, and billing data.
  - It enforces secure practices such as least-privilege and role-based access.
  - It encrypts connections and logs all activities (queries, logins, errors)
  - It is used to store, manage, and retrieve structured data for applications.

Samba

- What does Samba do?
  - Samba allows our Linux server to share files and printers with Windows machines.
  - It allows file and printer sharing across a network.
  - It provides a centralized storage solution.
- Why do we use it?
  - It is free of charge.
  - It allows your dentist office to store all information on one server instead of multiple. (reduces data loss and confusion).
  - It allows our staff who use Windows only systems to access data without having Linux experience.

    - It works with our Active Directory domain, allowing users to authenticate using their domain accounts.
    - Because of the Active Directory integration, user permissions are enforced per user or group.

WPS office

- What does WPS Office do?
    - WPS Office is a lightweight office suite like Microsoft Office.
    - It provides word processing, spreadsheets, and presentations.
- Why do we use it?
    - It allows your staff to create and edit documents, manage spreadsheets, and view files without the high cost that comes with Microsoft Office.
        - Microsoft Office (Business standard) comes in at a cost of $14 per user per month. You have 12 employees in total, that is $2,016 you are saving per year.
    - It allows administrators to create documentation and maintain logs or reports, and handle spreadsheets for billing or inventory.
    - It is not a resource intensive application.

Security Policies and Security software.

Nessus

- What does Nessus do?
  - Nessus is a tool that scans a computer system for any potential flaws in the system.
  - It is produced by Tenable.
  - It is trusted by the many cybersecurity experts.
- How does it build security?
  - It points out any flaws in a system, ranging from major company-destroying vulnerabilities to minor bugs.
  - The results of scans are used to build up a system's resilience.
  - It is said to discover vulnerabilities before the bad guys do.
- How do we use it?
  - We use it as a preventative measure against attacks.
  - We use it to discover holes in the infrastructure.
  - We use it to ensure that we set up tools and environments correctly.

Wazuh

- What is Wazuh?
  - Wazuh is a log aggregation tool.
  - It collects logs from windows machines into one source for easier log analysis.
  - It is classified as an XDR/SIEM (Extended Detection and Response/Security Information and Event Management) tool.
- How does it build security?
  - It detects different issues like unauthorized access attempts, malware, and policy violations.
  - It provides alerts to the IT department or the security team.
- How are we using it?
  - Wazuh collects logs from all of the servers we have.
  - An app is installed on each of the servers to collect logs.
  - Logs are sent back to the central Wazuh server for aggregation and easy viewing.

Security Controls

- These help protect individual accounts from being hijacked or hacked.
- These enforce things like good password management and account lockouts.
- These are built into the Windows Server and are configured to comply with the security policy.

- The security policy dictating these has been modeled after the NIST CSF. The definition of their recommended security policies starts on page 36.
- Enforcing these assists with reaching HIPAA compliance.

Group Policy

- These protect certain parts of the system from users on the system.
- These protect against privilege escalation attacks if an account is ever compromised.
- These also protect from internal attacks if there is ever a malicious disgruntled employee.
- These are a form of role-based access controls
    - Users can only access services and features that are necessary for their role.
    - Example: hygienists cannot log into the administrator's PC.
    - Example: Users that do not deal with customer finance cannot access customer financial records.
- This is configured according to the principle of least privilege.
    - This is the aspect that prevents privilege escalation.
    - Example: If a front desk worker's account is compromised, the hacker cannot change the password on an administrator account to get more privileges.
- Certain workers won't be able to log onto certain computers.
    - This prevents internal sabotage if an employee gets disgruntled.
    - Example: If a front desk worker wants to leak customer information, he won't be able to sign onto the computer that holds that information.

CIS Benchmarks v8

- This is a standardized guideline for security.
    - CIS Benchmarks v8 has received global recognition for its effectiveness in maintaining security
    - Step-by-step configuration checklists vetted by thousands of cybersecurity experts
    - Version 8 updated for modern threats — cloud environments and remote work
    - One consistent framework eliminates the inconsistency attackers exploit
- Policies and Procedures
    - Provides a repeatable, auditable process for how to secure systems — not just what to secure
    - Documents every configuration decision, creating a clear policy foundation
    - Maps directly to NIST CSF, HIPAA, and PCI-DSS

    - Demonstrates to auditors, insurers, and clients that practices meet an objective, third-party standard
- Forcing Encryption Over the Network
    - Most software defaults to convenience over security — often meaning unencrypted traffic
    - CIS Benchmarks mandate encrypted protocols across the board
    - Ensures data in transit cannot be intercepted or tampered with, on-premises or in the cloud
- Closing Unnecessary Ports
    - Every open port is a potential entry point for attackers
    - CIS Benchmarks require identifying and closing any port not actively needed
    - Shrinks the attack surface proactively — eliminating vulnerabilities before they can be exploited

Network Topology, DC Topology, and Redundancy.

Network Topology

- Network topology refers to the physical and logical arrangement of devices, connections, servers, switches, and client systems within the organization's network.
- Gulf Coast Dentistry currently uses a star topology, also referred to as a star-and-spoke design.
- In this design, endpoint devices such as workstations, printers, and servers connect back to a central switching point.

Why a Star Topology Was Chosen

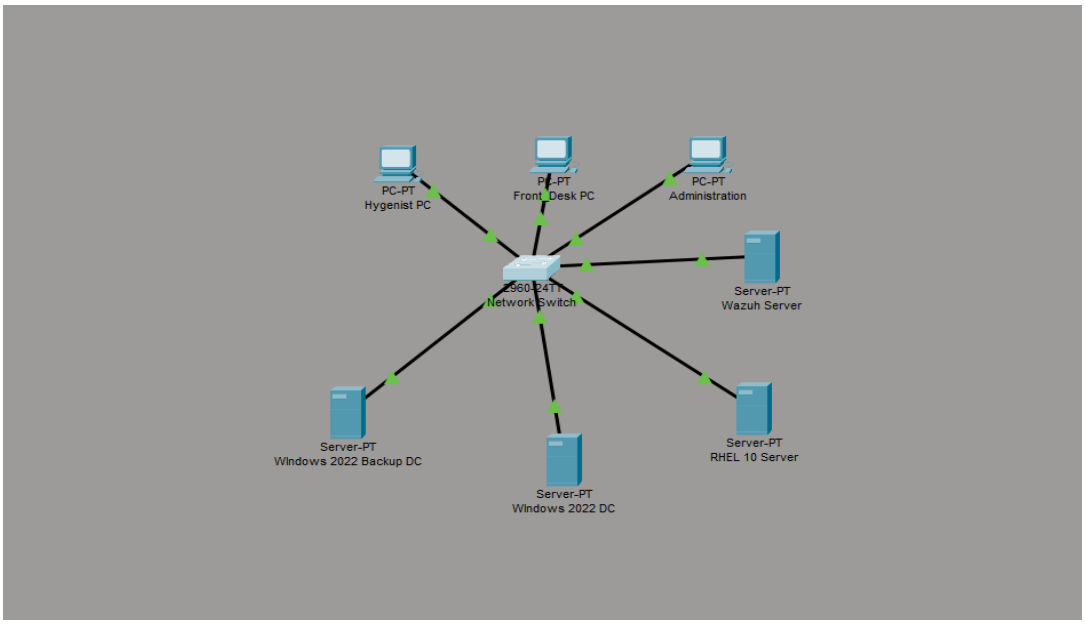
- Simple to expand - New devices can be added easily by connecting them to an available switch port. As the organization grows, additional switches can be added without redesigning the entire network.
- Easier to troubleshoot - Because each device has its own connection, problems are usually isolated to a single cable, port, or device. This makes identifying and correcting issues faster and more efficient.
- Limits the impact of individual failures - If one workstation, printer, or cable fails, the rest of the network continues operating normally. A single endpoint failure does not affect the entire office.
- Centralized management - The central switch provides a single point for managing traffic, VLANs, port security, and monitoring. Although the word hub is sometimes used informally to describe the center of the topology, the network uses a switch, not a hub, to manage traffic efficiently.

Consideration of This Design

- Single point of failure - One limitation of a star topology is that the central switch becomes critical infrastructure. If the central switch fails, connected endpoints may lose access to network resources until it is restored.

Domain Controller Topology

- A domain controller is a server that provides centralized authentication, authorization, and policy management for users and computers on the network.
- It plays a critical role in maintaining security, managing access, and enforcing organizational policies.

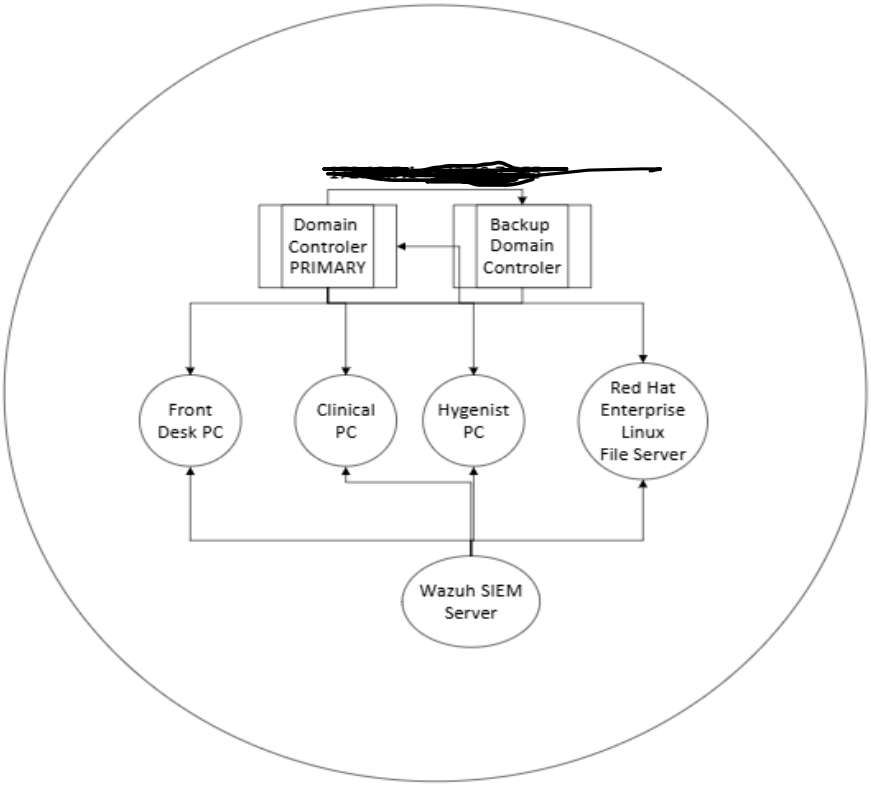


Primary Functions of the Domain Controller

- Authenticates user and computer logins
- Enforces Group Policy and other security settings
- Controls access to shared files, printers, and network resources
- Centralizes administrative control of the network environment

Why the Domain Controller Is Important

- It allows administrators to manage users, devices, and security settings from one centralized location.
- This improves consistency across systems and reduces the need to configure each workstation individually.
- It also strengthens security by ensuring that access control and policy enforcement are handled uniformly across the environment.



Redundancy

- Redundancy is the practice of having a secondary system available to take over if a primary system fails.
- Its purpose is to reduce downtime and maintain essential services during an outage or hardware failure.

Redundancy in Gulf Coast Dentistry

- Gulf Coast Dentistry uses a secondary Windows Server to support continuity if the primary domain controller becomes unavailable.

- If the primary server (WinServer - IPv4: [redacted]) fails or is taken offline, the backup server can continue providing core directory and policy services.
- This helps maintain authentication, access control, and policy enforcement during unexpected outages.

Benefits of Redundancy

- Reduces operational downtime
- Supports business continuity
- Maintains access to essential network services
- Helps preserve security and policy enforcement during system failures

Backups

- A backup is a retained copy of a system or virtual machine that can be restored if the original system is lost, corrupted, or compromised.
- Backups are an essential part of disaster recovery and long-term business continuity planning.

Backup Strategy at Gulf Coast Dentistry

- Copies of virtual machines are taken every Thursday.
- Two weeks of backups are retained.
- If the most recent backup is unavailable or unusable, the previous week's backup remains available for recovery.

Why Backups Are Necessary

- Protect against data loss caused by hardware failure
- Support recovery from malware or unauthorized system changes
- Allow systems to be restored in a timely manner after an outage
- Reduce the impact of cyber incidents and operational disruptions

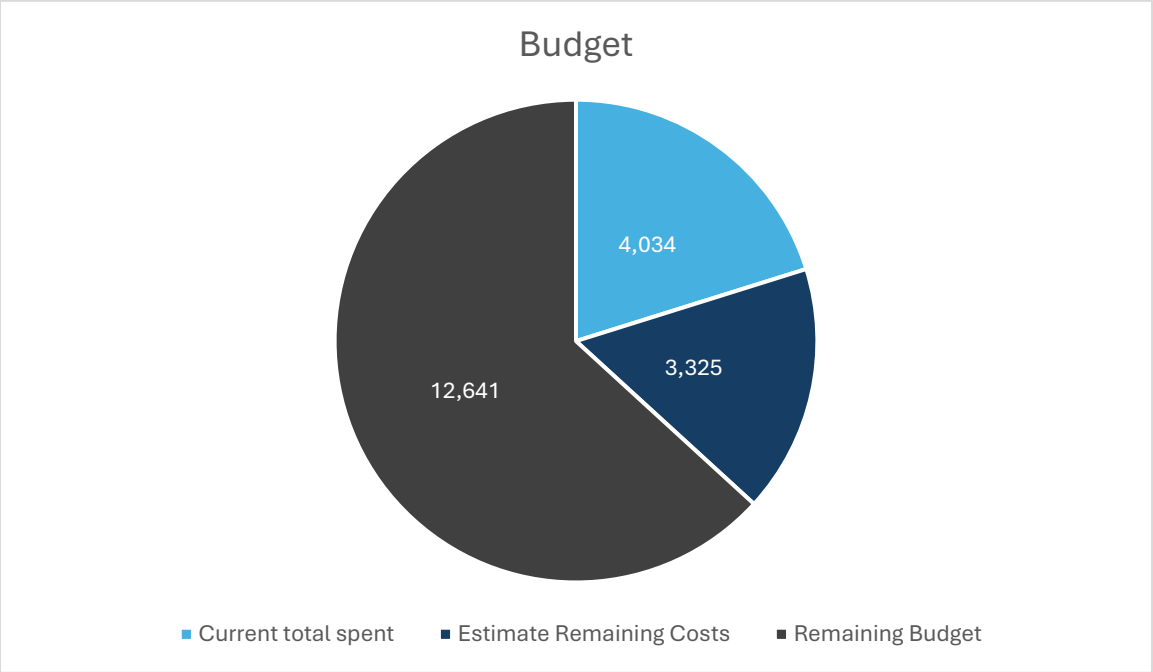
Conclusion

- Network topology reduces the effects of an outage of one computer on other computers. Keeps costs low in an outage and time to repair low.
- Backups help reduce the time to repair by being able to have a new machine up and running for almost no cost.
- Redundancy helps reduce costs by providing an immediate backup in case the domain controller experiences an outage. It maintains high security and ensures policies are always enforced. It also keeps expenses lower and minimizes repair time.

Finances/Where we are headed

1. Current Financial Position
   - Labor Investment - $ 3,155.11(18 hours)
     - System architecture and configuration
     - Domain services deployment
     - Security hardening and access controls
     - Testing, validation, and documentation
     - Structured implementation to prevent costly rework
   - Licensing - $878.90 (yearly subscription)
     - Red Hat Enterprise Linux enterprise subscription
     - Ongoing security patches and updates
     - Vendor-backed support
     - Long-term system stability and compliance readiness
2. Why This Is Financial Smart
   - Costs We Avoided:
     - Proprietary server ecosystems with high licensing overhead
     - Large upfront capital hardware investments
     - Over-provisioned or unnecessary software packages
     - Long-term vendor lock-in
   - We chose:
     - Enterprise-grade open-source infrastructure
     - Scalable system design
     - Controlled operational spending
     - Security-first architecture
3. Financial Risk Reduction
   - Our investment helps prevent significantly higher potential losses, including:
     - Data breach response and legal remediation
     - HIPAA regulatory penalties
     - Ransomware recovery and system restoration
     - Lost revenue from operational downtime
     - Emergency third-party IT consulting fees
     - Reputational damage impacting patient retention
4. Financial Outlook & Strategic Growth
   - Remaining Projected Time/Costs
     - Pentesting
       - Time: 6-8 hours

    - Cost: $1,050-$1,400
- Additional Security Hardening / Configuration
    - Time: 3-5 hours
    - Cost: $525-$875
- User Manual Creation
    - Time: 4-6 hours
    - Cost: $700-$1,050
- **Total Remaining Effort**
    - **Time: 13-19 hours**
    - **Projected Cost: $2,275-$3,325**



- Short-Term
    - Annual RHEL subscription renewal
    - Minor scaling costs as the practice grows
- Long-Term Strategic Considerations
    - Cyber insurance optimization opportunities
    - Periodic security audits and compliance validation
    - Disaster recovery expansion
    - Infrastructure scaling to support additional providers or locations